

A Secure Lightweight Authentication Scheme in IoT Environment with Perfect Forward and Backward Secrecy

E Haodudin Nurkifli

Department of Computer Science
and Information Engineering,
(National Cheng Kung University)
Faculty of Computer Science
(Universitas Singaperbangsa
Karawang)

Tainan, Taiwan

dudi.nurkifli@staff.unsika.ac.id.
P78067011@gs.ncku.edu.tw,
ORCID:0000-0003-3637-1172

Tzonelih Hwang

Department of Computer Science
and Information Engineering,
(National Cheng Kung
University)

Tainan, Taiwan

hwangtl@mail.csie.ncku.edu.tw,
hwangtl@csie.ncku.edu.tw,
ORCID: 0000-0003-3881-1362

Abstract—Emerging cutting-edge technology can change the daily life of human beings, for instance, smart transportation, intelligent healthcare systems, Smart cities, etc. Human can use their device to access other devices remotely to collect and utilize the information for their work. Internet of Things is the backbone of the autonomous environment aforesaid. However, IoT uses the public channel to transmit information, and it opens the opportunity for attackers to intercept, delete, and modify data. Therefore, security is an imperative aspect of IoT technology. One of the critical security features is perfect forward and backward secrecy. This article proposes new protocol authentication using biometrics and Physically Unclonable Function (PUF) with the primary security feature of achieving Perfect Forward and Backward Secrecy (PFBS). Our protocol also achieves other security features such as anonymity, unclonable device, and mutual authentication. In addition, we conduct informal and formal analyses to prove that the protocol achieves security features.

Keywords—IoT, PFBS, informal and formal analyses

I. INTRODUCTION

Applications of IoT systems increase rapidly. Many fields demand IoT systems, including healthcare, military, manufacturing, agriculture, transportation systems, nuclear industry, etc. However, the public channel between IoT devices causes a lot of risks and threats. It allows the adversary to intercept, alter, and delete any transmitted message. Hence, a guarantee of security and privacy is an imperative aspect of IoT systems. Additionally, resource constraints of IoT devices pose a challenge to researchers, which makes classical cryptographic primitives not suitable for IoT systems due to their heavy computational overhead.

Several researchers, T. Mcgrath et al. [1], C. Herder et al. [2], and A. Babaei and G. Schiele [3], have introduced Physical Unclonable Function (PUF) as an alternative to applying a limited resource, like IoT equipment. However, F. Ganji et al. [4], J. Delvaux [5], and U. Rührmair and J. Solter [6] describe that independently the PUF is vulnerable to learning attack/machine learning attack. However, Machine-learning attacks cannot collect many challenge-response pairs if the challenge and responses are secret. Unfortunately, most previous protocol security does not protect challenge C; hence the attacker can compute response R from challenge C. Therefore, it suffers machine learning attacks.

Recently, Aman et al. [7] proposed the security protocol in IoT systems using physically unclonable functions (PUF). Additionally, in the other time, P. Gope [8] also proposed a security protocol using PUF. However, our rigorous review

shows that their schemes fail to achieve PFBS. The evidence is the IoT application uses a public channel to transmit messages hence the attacker can collect all data from that channel, including challenge C. In addition, the attacker can capture the device because the IoT device is commonly put in a public space. Later, the attacker can fully control the device, activate PUF by programming, and compute the correct response R using challenge C where $R=PUF(C)$. Then, the attacker can generate past and future secret credentials. Therefore, the protocol of Aman et al. [7] and P. Gope [8] fail to achieve PFBS.

In this paper, we proposed a new security protocol in IoT Systems using PUF and biometrics that resolves the main flaw in previous protocols: PFBS. In addition, our protocol achieves other security properties, including mutual authentication, anonymity, and an unclonable device. Our protocol also withstands DoS and impersonation attacks. On the other side, we conduct informal analysis with solid reasoning logic, and formal analysis uses Boyd and Mao Logic to ensure that our protocol fulfills security properties.

The rest of the paper is organized as follows. Section II presents related work and contributions. Then Section III presents preliminaries. Detail discussion of the proposed protocol is in Section IV. Section V presents the informal and formal analysis. The comparison between our proposal and previous protocol regarding security features and capability to withstand well-known attacks is in Section VI—finally, the conclusion is in Section VII.

II. RELATED WORK AND CONTRIBUTION

The academics conduct survey research in IoT systems such as M. El-hajj et al. [9], F. Meneghello et al. [10], and R. Román-castro and J. López [11]. However, their article does not provide addressing the security issues. In addition, the other research on mutual authentication protocol using ECC was proposed by A. K. Das [12], J. Ryu et al. [13], and RSA offered by T. Kothmayr et al. [14], and bilinear pairing proposed by M. Nikravan [15]. However, the public-key cryptography algorithm has a heavy computational burden; hence, it is unsuitable for IoT devices with limited resources. Several researchers proposed an authentication protocol using primitive cryptography to resolve computational burden issues, such as authentication protocol using XOR and Hash Function proposed by P. Gope and T. Hwang [16] and AES presented by K. L. Tsai [17]. Unfortunately, their protocol is vulnerable to well-known attacks, including cloning attacks.

Several researchers T. Mcgrath et al [1], C. Herder [2], and A. Babaei and G. Schiele [3] introduced PUF as an alternative cryptography algorithm to apply to a tiny device. However, the researcher utilizes the PUFFs only to generate keys and authentication offered by G. E. Suh and S. Devadas [18]; several researchers extend the usage of PUF for supporting encryption and decryption processes W. Choi [19]. The other researcher S. Kleber et al. [20] offers a code encryption engine based on PUFs for keeping a secure execution environment. The sender and receiver have access to the same PUF on the same platform. However, Y. Guo, T. Dee, and A. Tyagi [21] point out that the proposed S. Kleber et al. [20] has violated the assumption because both the sender and receiver have separate and distinct PUFs.

Y. Guo, T. Dee, and A. Tyagi [21] proposed Barrel Shifter Physical Unclonable Function-Based Encryption, the authors rely on PUF for the encryption-decryption process. However, the scheme fails to achieve mutual authentication, anonymous device, etc. Additionally, independently the PUF is vulnerable to learning attack C. Herder [2]; the other research gives the term machine learning attack F. Ganji et al. [4], J. Delvaux [5], and U. Rührmair and J. Solter [6]. However, a Machine-learning attack is hard to apply due to is based on the assumption the attacker has collected many challenge-response pairs and then predicts R based on C.

Recently, Aman et al. [7] proposed the security protocol, namely mutual authentication in IoT systems using physically unclonable functions. However, P. Gope [8] show that their scheme Aman et al. [7] cannot ensure the privacy of IoT device. P. Gope [8] proposed a lightweight and privacy-preserving two-factor authentication scheme for IoT devices. They claim that the system achieves security properties, including mutual authentication and anonymity. However, based on our analysis, P. Gope [8] fails to achieve anonymity; we show the evidence follows after the attacker collects challenges from the public channel and generates a correct response. The attacker computes a new challenge. If the new challenge calculated by the attacker is equal to the new challenge obtained from the public channel, the attacker will know the owner of the new challenge; it is a violation of anonymity. In addition, the P. Gope [8] cannot achieve PFBS.

PFBS is a critical security feature. We divide the definition of perfect forward and backward secrecy (PFBS) into two types. First is the weak PFBS, where the attacker can fully control the device and gets the secret credentials. However, the attacker cannot obtain past and future private data. The second is the strong PFBS, where the attacker can fully control the device. Still, the attacker cannot get the secret credential because a biometric key protects the private data; hence the attacker cannot get past and future confidential data.

This article proposed to resolve the security issues with the contribution as follows.

1. Designing a new lightweight authentication protocol
2. Proposed strong PFBS
3. We conduct the informal analyses to ensure that our protocol achieves security features such as anonymity, mutual authentication, and unclonable device.
4. The informal analyses also ensure that our protocol withstands well-known attacks such as DoS, Impersonation, and Cloning attacks.

5. We conducted the formal analyses of Mao and Boyd logic to strengthen informal evidence that our protocol fulfills security features.

III. PRELIMINARIES

The background of the PUF and the Fuzzy Extractor (FE) are as follows.

A. PUF

The PUF utilizes the unique circuit property; it maps challenge-response pairs in the chip manufacturing process G. E. Suh and S. Devadas [18]. On formal equation $R=PUF(C)$, where PUF generates response R from Challenge C. C. Bohm and M. Hofe [22]. There are two types of PUF. First, the ideal PUF produces the same output response R from input challenge C. The second Non-ideal PUF generates a different response R from an equal input Challenge C. To address non-ideal PUF issues, we can use a Fuzzy Extractor, where the Fuzzy extractor can produce stable PUF output. Unfortunately, it can increase computational overhead P. Tuyls and L. Batina [23], Y. Dodis, L. Reyzin, and A. Smith [24]. On the other hand, to resolve computational burden issues, several researchers proposed ideal PUFs such as D. Jeon et al. [25], K. Chuang et al. [26], X. Lu et al. [27], and W. Wang [28], ensuring a 0 % error rate of PUF output, proving that PUF has stable output. Therefore, we use the ideal PUF in this article.

B. Fuzzy Extractor (FE).

The fuzzy extractor (FE) usage for omitting the noise in the biometric, FE has the equation as follows $(K_u, hd) = FE.Gen(Bio_u) \rightarrow (K_u) = FE.Rec(hd, Bio'_u)$, where $FE.Gen()$ generates {key and helps data} from biometric input, while $FE.Rec()$ reconstructs keys from {help data and biometric input}. In addition, biometrics may change cause the time; hence, the noise from biometric input emerges. Bio_u is the user's biometric, and Bio'_u is the user's biometric with noise. Therefore, the hamming distance from Bio_u and Bio'_u is less than or equal to the threshold with the equation $dis(Bio_u, Bio'_u) \leq t$ where t is the threshold.

IV. PROPOSED SCHEME

This Section presents our proposed protocol starting from System Architecture, Assumptions, Cryptographic function, and the Phases of the protocol.

A. System Architecture

Fig. 1 depicts the IoT device collecting data from the patient, such as body temperature, blood pressure, ECG, and EMG. And then send them to the server via the internet. The server is a database that stores all the data collected from the device. Only legitimate users can use the device, and only authorized devices can communicate with the server. The system architecture on our proposal focuses on IoT-based healthcare systems S. M. R. Islam [29], L. Catarinucci et al. [30], H. Habibzadeh et al. [31], and P. A. Laplante et al. [32].

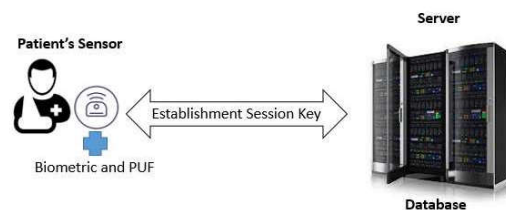


Fig. 1. System Structure in IoT Environment.

B. Assumption

The assumptions are as follows

1. The device is equipped with biometric and PUF
2. The device has limited resources and memory
3. The server has no limited resources and memory

C. The Notation of Cryptography Function

The cryptography notations are shown in TABLE I.

TABLE I. Cryptographic Notations

Notation	Descriptions
ID_A	Identity of the IoT Device
K_{AS}	Shared key between server and IoT device
PUF_A	Physically unclonable function of IoT Device
PID_{AS}	Pseudo identity of device to communicate with server
C_A, R_A	Challenge – Response Pairs
PID_{Syn}	Pseudo identity of synchronization is used if desynchronization occurs where $PID_{Syn} = \{pid_1, \dots, pid_n\}$
K_{Syn}	Key of synchronization is used if desynchronization occurs where $K_{Syn} = \{pk_1, \dots, pk_n\}$
SK	Session key between IoT device and Server
β_u	Biometric of the user
FE	Fuzzy extractor K_u denotes key, hd denotes help data, where $FE.Gen()$ function conducts generating biometric and then produces a key and help data the equation is $(K_u, hd) = FE.Gen(B_u)$. To reconstruct the key is shown by equation $(K_u) = FE.Rec(B_u, hd)$

D. Proposed Protocol

The Subsection presents our proposed protocol, where the proposed scheme consists of two phases. Phase I is a registration, and Phase II is the Login and mutual authentication between the IoT device and the server, as shown in Fig. 2 and Fig. 3. The detailed steps of each phase are as follows

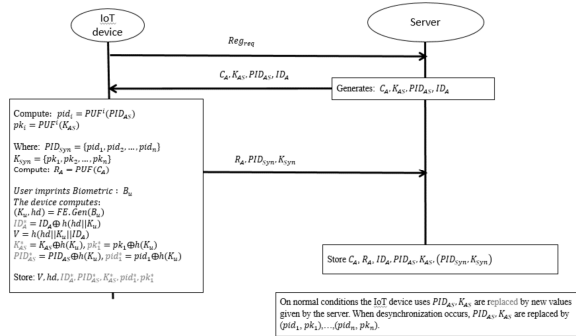


Fig. 2. Registration Phase

1.P hase I: IoT device Registration

Step 1: The IoT device sends $RegReq$ to the server.

Step 2: The server generates $C_A, K_{AS}, PID_{AS}, ID_A$ and sends them to the IoT device.

Step 3: The IoT device computes $pid_i = PUF^i(PID_{AS})$, $pk_i = PUF^i(K_{AS})$ where $PID_{Syn} = \{pid_1, pid_2, \dots, pid_n\}$ and $K_{Syn} = \{pk_1, pk_2, \dots, pk_n\}$. The IoT device computes $R_A = PUF(C_A)$. The IoT device sends R_A, PID_{Syn}, K_{Syn} to the server.

Step 4: User imprints Biometric B_u

Step 5: The device computes $(K_u, hd) = FE.Gen(B_u)$

Step 6: The device computes $ID_A = ID_A \oplus h(hd || K_u)$

Step 7: The IoT device computes $V = h(hd || K_u || ID_A)$

Step 8: The IoT device computes $K_{AS}^* = K_{AS} \oplus h(K_u)$, $pk_1^* = pk_1 \oplus h(K_u)$

Step 9: The IoT device also compute $PID_{AS}^* = PID_{AS} \oplus h(K_u)$, $pid_1^* = pid_1 \oplus h(K_u)$

Step 10: Finally, the server stores $C_A, R_A, ID_A, PID_{AS}, K_{AS}, (PID_{Syn}, K_{Syn})$ and the IoT device stores $V, hd, ID_A^*, PID_{AS}^*, K_{AS}^*, pid_1^*, pk_1^*$. Initialization phase via a secure channel.

Under normal conditions, the IoT device uses PID_{AS}, K_{AS} are replaced by new values $\{PID_{AS}^{new}, K_{AS}^{new}\}$ given by the server. However, If desynchronization occurs, PID_{AS}, K_{AS} are replaced by $(pid_1, pk_1), \dots, (pid_n, pk_n)$.

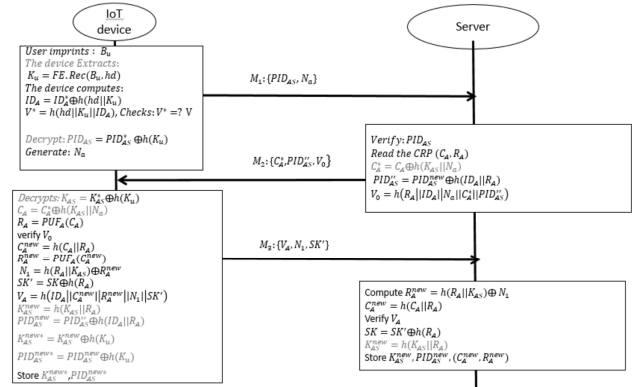


Fig. 3. Login and Mutual Authentication between IoT device and Server

2.P hase II: Login and Mutual authentication between IoT device and Server

Login and Mutual authentication between IoT device and server phase as follows.

Step 1: The user imprints biometric B_u

Step 2: The IoT device extracts $K_u = FE.Rec(B_u, hd)$

Step 3: The IoT device computes $ID_A = ID_A^* \oplus h(hd || K_u)$

Step 4: The IoT device compute $V^* = h(hd || K_u || ID_A)$

Step 5: The IoT device checks $V^* =? V$, if V^* is not equal to V the login will be terminated, otherwise, the user can use the device and then perform mutual authentication between IoT device and server.

Step 6: The IoT device decrypts $PID_{AS} = PID_{AS}^* \oplus h(K_u)$, generate N_a , and then sends $M_1: \{PID_{AS}, N_a\}$ to the Server

Step 7: Upon receiving $M_1: \{PID_{AS}, N_a\}$. Then, the Server verifies PID_{AS} that is related to ID_A in the database; if the Server does not find PID_{AS} in the database, the Server will terminate communication. Otherwise, the Server reads the $CRP(C_A, R_A)$ and computes the protected Challenge $C_A^* = C_A \oplus h(K_{AS} || N_a)$. The Server decides to compute $PID_{AS}'' = PID_{AS}^{new} \oplus h(ID_A || R_A)$, and the server copies and stores PID_{AS}^{new} . The Server computes the authentication code $V_0 = h(R_A || ID_A || N_a || C_A^* || PID_{AS}'')$, The Server sends $M_2: \{C_A^*, PID_{AS}'', V_0\}$ to the IoT device.

Step 8: Upon receiving $M_2: \{C_A^*, PID_{AS}'', V_0\}$ the IoT device decrypts $K_{AS} = K_{AS}^* \oplus h(K_u)$, computes $C_A = C_A^* \oplus h(K_{AS} || N_a)$, generates R_A , where $R_A = PUF(C_A)$, verify V_0 , compute new challenge $C_A^{new} = h(C_A || R_A)$,

compute $R_A^{new} = PUF_A(C_A^{new})$, $N_1 = h(R_A || K_{AS}) \oplus R_A^{new}$, Compute $SK' = SK \oplus h(R_A)$, compute $V_A = h(ID_A || C_A^{new} || R_A^{new} || N_1 || SK')$ and then the IoT device sends $M_3: \{V_A, N_1, SK'\}$ to the server. IoT device updates $K_{AS}^{new} = h(K_{AS} || R_A)$, the IoT device computes $PID_{AS}^{new} = PID_{AS} \oplus h(ID_A || R_A)$ and IoT device encrypts $K_{AS}^{new*} = K_{AS}^{new} \oplus h(K_u)$, $PID_{AS}^{new*} = PID_{AS}^{new} \oplus h(K_u)$ and store $K_{AS}^{new*}, PID_{AS}^{new*}$.

Step 9: Upon receiving $M_3: \{V_A, N_1, SK'\}$, the Server computes $R_A^{new} = h(R_A || K_{AS}) \oplus N_1$, $C_A^{new} = h(C_A || R_A)$, then verify V_A , the server obtains SK by computing $SK = SK' \oplus h(R_A)$. The server computes $K_{AS}^{new} = h(K_{AS} || R_A)$, Finally, the server stores $K_{AS}^{new}, PID_{AS}^{new}, (C_A^{new}, R_A^{new})$.

SK is a session key, it is generated randomly by IoT device, and IoT device sends SK encrypted by $h(R_A)$ where $SK = SK' \oplus h(R_A)$. After mutual authentication, the IoT device and server use SK to establish secure communication.

3. Resolve the desynchronization problem

Step 1: The IoT device replaces PID_{AS}, K_{AS} , by pid_1, pk_1 if occurs desynchronization

Step 2: The protocol executes a similar step to the authentication phase.

Step 3: Additionally, the IoT device computes pid_2 based on pid_1 where $pid_2 = PUF(pid_1)$.

V. ANALYSIS

This section presents the achievement of security features and comparison. We divide the analysis into two types, the first informal analysis is the analysis based on intuitive reasoning, and the second one is the formal analysis using a mathematical model. We use Mao and Boyd Logic for analysis formally. Finally, we also show a comparison result of achieving security features with previous state-of-the-art protocols proposed by [7] and [8].

A. Informal Analysis

This subsection shows our protocol's result in achieving security properties and withstanding a well-known attack under informal analysis. The result is as follows.

1. Mutual authentication

The evidence that our protocol achieves mutual authentication. The IoT device can authenticate the Server by possessing shared Key K_{AS} and R_A . and vice-versa. In addition, to ensure the freshness, the IoT device checks the nonce N_a , and the Server checks N_1 . Therefore, our protocol achieves mutual authentication.

2. Preserving Device Anonymity

Anonymity can be achieved if the attacker cannot get an actual identity. Our protocol IoT device uses pseudo identity PID_{AS} in each communication with the server. Even if the attacker can get all messages from the public channel, the attacker cannot know the identity of the IoT device. Therefore, our protocol achieves device anonymity.

3. Resolve the desynchronization

The evidence that our protocol resolved the desynchronization problem. If desynchronization occurs, the IoT device replaces PID_{AS}, K_{AS} , by pid_1, pk_1 . The protocol follows the same step as the authentication phase. Then, the

IoT device computes pid_2 based on pid_1 where $pid_2 = PUF(pid_1)$ for use in communicating at the next session.

4. Unclonable device

The PUF can guarantee the unclonable device. Therefore, our protocol achieves an unclonable device.

5. PFBS

Our protocol achieves PFBS with evidence as follows. Our protocol encrypts all secret credentials such as $V, hd, ID_A^*, PID_{AS}^*, K_{AS}^*, pid_1^*, pk_1^*$. Suppose the attacker captures the device and gets all messages from the public channel. The attacker cannot generate secret credentials, including C, R, and K_{AS} . On the other side, our protocol updates all keys in every session; hence there is no relation between them. Therefore, the attacker cannot get the past and future secret keys.

6. Withstand tracking attack

Our protocol encrypts all secret credentials and updates every session, including the challenge; hence the attacker cannot generate R from C. In addition, our protocol doesn't publish the real identity. The attacker is impossible to track the device. Therefore, Our protocol withstands tracking attacks.

7. Withstand DoS attack

The evidence that our protocol resists the DoS attack is as follows. Suppose the Desynchronization occurs, the device substitutes {pseudo identity and shared key} by {pseudo identity, shared-key synchronization}. In the final stage, the device updates {pseudo identity, shared-key synchronization}. Therefore, our protocol can resolve desynchronization and withstand the DoS attack.

8. Impersonation attack

Our protocol protects data $V, hd, ID_A^*, PID_{AS}^*, K_{AS}^*, pid_1^*, pk_1^*$ with a biometric key K_u . Even if the attacker captures the device and obtains data from memory, the attacker only obtains the non-plaintext data. Therefore, our protocol withstands an impersonation attack.

B. Formal Analysis

The security analysis of mutual authentication between IoT device A and Server S is as follows. we show that the secrets K_{AS}^{new} and R_A^{new} are well-shared keys between IoT device A and Server S. (i.e., the attackers can't obtain these secrets). The formal analysis using Mao and Boyd logic starts from creating an ideal message in the protocol, initial beliefs, assumptions, and proof that the protocol achieves mutual authentication. (for detailed theoretical Mao and Boyd Logic, See references M. Kaveh [33] and W. Mao and C. Boyd [34])

1. ideal message in mutual authentication between IoT device A and Server S is as follows:

- $A \rightarrow S: A, N_a$
- $S \rightarrow A: S, \{C_A\}_{K_{AS}}, \{R N_a\}_{R_A}$
- $A \rightarrow S: A, \{C_A^{new} R R_A^{new} RN_1\}_{R_A, K_{AS}}$

2. The initial beliefs or assumption as follow:

- $A \models A \leftrightarrow^R S$ and $S \models A \leftrightarrow^R S$: S stores CRP of the IoT device in its memory at setup phase.

- b. $A \equiv A \xleftrightarrow{K_{AS}} S$ and $S \equiv A \xleftrightarrow{K_{AS}} S$: S generates K_{AS} and stores K_{AS} . IoT device also stores K_{AS}
- c. $A \equiv \{A\}^C \triangleleft ||R_A^{new}, S \equiv A \equiv \{A\}^C \triangleleft ||R_A^{new}$: A and S believe the new response R_A^{new} is generated by A
- d. $A \equiv S \equiv \{S\}^C \triangleleft ||K_{AS}^{new}$ and $S \equiv A \equiv \{A\}^C \triangleleft ||K_{AS}^{new}$: A and S believe the new shared key K_{AS}^{new} generated by A and S based on K_{AS} and R_A
- e. $A \equiv \#(R_A^{new})$: A generates new response R_A^{new} each time
- f. $A \equiv \#(K_{AS}^{new})$ and $S \equiv \#(K_{AS}^{new})$: A and S generate new share key each time
- g. $A \equiv \#(N_a)$: A generates new N_a each time
- h. $A \equiv \#(N_1)$: A generates new N_1 each time
- i. $S \mid \sim C_A$ and $S \mid \sim R N_a$: Message in the idealized protocol
- j. $A \xrightarrow{K_{AS}} C_A$ and $A \xrightarrow{R_A} R N_a$: Message in the idealized protocol
- k. $A \mid \sim^{K_{AS}, R_A} C_A^{new} R R_A^{new} R N_1$: Message in the idealized protocol
- l. $S \xrightarrow{K_{AS}, R_A} C_A^{new} R R_A^{new} R N_1$: Message in the idealized protocol
- m. $S \equiv \sup(X)$: X is super principal with respect to R_A^{new} and K_{AS}^{new}
- n. $A \equiv \sup(S)$: X is super principal with respect to K_{AS}^{new}
- o. $A \equiv \{A\}^C \triangleleft ||SK$: A believes the new session key is generated by A
- p. $A \equiv \#(SK)$: A generates new session key each time

3. Shows the proof of the fact that:

- a. A believes R_A^{new} is a new good shared

$$\frac{A \mid \sim^{R_A} S \wedge A \mid \sim \{A\}^C \triangleleft ||R_A^{new} \wedge A \mid \sim^{K_{AS}, R_A} C_A^{new} R R_A^{new} R N_1}{A \mid \sim \{A, S\}^C \triangleleft ||R_A^{new}} : \text{The Confidentiality Rule}$$

$$\frac{A \mid \sim \{A, S\}^C \triangleleft ||R_A^{new} \wedge A \mid \sim \#(R_A^{new})}{A \mid \sim A \xrightarrow{R_A^{new}} S} : \text{The Good-key rule}$$

- b. S believes R_A^{new} is a new good shared

$$\frac{S \xrightarrow{K_{AS}, R_A} C_A^{new} R R_A^{new} R N_1}{S \xrightarrow{K_{AS}, R_A} C_A^{new} \wedge S \xrightarrow{K_{AS}, R_A} R R_A^{new} \wedge S \xrightarrow{K_{AS}, R_A} R N_1} : \text{The intuitive rule}$$

$$\frac{S \mid \sim^{R_A} S \wedge S \mid \sim^{K_{AS}, R_A} R R N_1}{S \mid \sim A \mid \sim^{K_{AS}, R_A} R N_1} : \text{The Authentication Rule}$$

$$\frac{S \mid \sim \#(N_1) \wedge S \mid \sim A \mid \sim^{K_{AS}, R_A} R N_1}{S \mid \sim A \mid \sim^{R_A} S} : \text{The Non-verification Rule}$$

$$\frac{S \mid \sim^{R_A} S \wedge S \xrightarrow{K_{AS}, R_A} R R_A^{new}}{S \mid \sim A \mid \sim^{K_{AS}, R_A} R R_A^{new}} : \text{The Authentication Rule}$$

$$\frac{S \mid \sim A \mid \sim^{R_A} S \wedge S \mid \sim A \mid \sim \{A\}^C \triangleleft ||R_A^{new} \wedge S \mid \sim A \mid \sim^{K_{AS}, R_A} C_A^{new} R R_A^{new} R N_1}{S \mid \sim A \mid \sim \{A, S\}^C \triangleleft ||R_A^{new}} : \text{The Confidentiality Rule}$$

$$\frac{S \mid \sim A \mid \sim \{A, S\}^C \triangleleft ||R_A^{new} \wedge S \mid \sim \sup(A)}{S \mid \sim \{A, S\}^C \triangleleft ||R_A^{new}} : \text{The super-principal rule}$$

$$\frac{S \mid \sim \#(N_1) \wedge S \xrightarrow{K_{AS}, R_A} R R_A^{new} R N_1}{S \mid \sim \#(R_A^{new})} : \text{The fresh rule}$$

$$\frac{S \mid \sim \{A, S\}^C \triangleleft ||R_A^{new} \wedge S \mid \sim \#(R_A^{new})}{S \mid \sim S \xrightarrow{R_A^{new}} A} : \text{The Good-key Rule}$$

- c. A believes K_{AS}^{new} is a new good shared

$$\frac{A \mid \sim A \xrightarrow{K_{AS}} S \wedge A \mid \sim \{A\}^C \triangleleft ||K_{AS}^{new} \wedge A \mid \sim^{K_{AS}, R_A} K_{AS}^{new}}{A \mid \sim \{A, S\}^C \triangleleft ||K_{AS}^{new}} : \text{The Confidentiality Rule}$$

$$\frac{A \mid \sim \{A, S\}^C \triangleleft ||K_{AS}^{new} \wedge A \mid \sim \#(K_{AS}^{new})}{A \mid \sim A \xrightarrow{K_{AS}^{new}} S} : \text{The Good-key Rule}$$

- d. S believes K_{AS}^{new} is a new good shared

$$\frac{S \mid \sim S \xrightarrow{K_{AS}} A \wedge S \mid \sim \{S\}^C \triangleleft ||K_{AS}^{new} \wedge S \mid \sim^{K_{AS}, R_A} K_{AS}^{new}}{S \mid \sim \{A, S\}^C \triangleleft ||K_{AS}^{new}} : \text{The Confidentiality Rule}$$

$$\frac{S \mid \sim \{A, S\}^C \triangleleft ||K_{AS}^{new} \wedge S \mid \sim \#(K_{AS}^{new})}{S \mid \sim S \xrightarrow{K_{AS}^{new}} A} : \text{The Good-key Rule}$$

The result of Mao-and-Boyd logic proves that our protocol achieves mutual authentication with evidence that each party authenticates mutually one other by possessing the shared keys $\{K_{AS}, R_A\}$. In addition, our protocol withstands the reply attack due to preserving the freshness using nonce $\{N_a, N_1\}$. Our protocol updates all secret credentials in every session, including the nonce $\{N_a, N_1\}$. If the attacker attempts to conduct the reply attack, each party can easily detect whether the message is modified or not using a new nonce. Therefore, our protocol can achieve mutual authentication and withstand a reply attack.

VI. COMPARISON

The section compares our proposed with two popular current schemes regarding security features and the capability to resist attack. The comparison is the below:

TABLE II. COMPARISON RESULT

Competencies	Aman et al.'s Scheme [7]	P. Gope et al.'s scheme [8]	Our proposed
Achievement of PFBS	X	X	✓
Anonymity	X	X	✓
Resolve Desynchronization problem	X	✓	✓
Unclonable device	✓	✓	✓
Withstand impersonation attack	X	X	✓

Withstands Tracking attack	X	X	✓
Withstand DoS attack	X	✓	✓

We have compared our scheme with two state-of-the-art protocols proposed by Aman et al. [7] and P. Gope [8]. Table I shows that Aman et al. [7] only achieved an unclonable device. At the same time, P. Gope [8] can resolve desynchronization and withstand the DoS attack, as well as an unclonable device. Unfortunately, P. Gope [8] fails to achieve anonymity and PFBS and fails to withstand impersonation and tracking attacks. In contrast, only our protocol fulfills security features and resists well-known attacks.

VII. CONCLUSION

This article proposed a new security protocol in IoT Systems. Our scheme can resolve the main weakness of their scheme, namely PFBS. In addition, our proposed protocol fulfills security properties, including mutual authentication, an unclonable device, and preserving the anonymity device. Our protocol also withstands DoS, tracking, and impersonation attacks. In addition. The formal analysis also shows that our protocol achieved secure mutual authentication and withstood reply attacks.

ACKNOWLEDGMENT

The authors would like to thank National Cheng Kung University and Universitas Singaperbangsa Karawang has supported this research. In addition, thank all anonymous reviewers for their suggestions.

REFERENCES

- [1] T. Mcgrath et al., "A PUF taxonomy A PUF taxonomy," *Appl. Phys. Rev.*, vol. 6, p. 011303, 2019.
- [2] C. Herder, M. Yu, F. Koushanfar, and S. Devadas, "Physical Unclonable Functions and Applications : A Tutorial," *Proc. IEEE*, vol. 102, no. 8, pp. 1126–1141, 2014.
- [3] A. Babaei and G. Schiele, "Physical Unclonable Functions in the Internet of Things : State of the Art and Open Challenges," *Sensors (Basel)*, vol. 19, no. 14, p. 3208, 2019.
- [4] F. Ganji, S. Tajik, F. Fabian, and J. Seifert, "Strong Machine Learning Attack against PUFs with No Mathematical Model," *18th Int. Conf. -Cryptographic Hardw. Embed. Syst. - CHES 2016*, pp. 1–21, 2016.
- [5] J. Delvaux, "Machine-Learning Attacks on PolyPUFs, OB-PUFs, RPUFs, LHS-PUFs, and PUF-FSMs," *IEEE Trans. Inf. FORENSICS Secur.*, vol. 14, no. 8, pp. 2043–2058, 2019.
- [6] U. Rührmair and J. Solter, "PUF Modeling Attacks: An Introduction and Overview," *2014 Des. Autom. Test Eur. Conf. Exhib.*, pp. 1–6, 2014.
- [7] M. N. Aman, K. C. Chua, and B. Sikdar, "Mutual Authentication in IoT Systems Using Physical Unclonable Functions," *IEEE Internet Things J.*, vol. 4, no. 5, pp. 1327–1340, 2017.
- [8] P. Gope, "Lightweight and Privacy-Preserving Two-Factor Authentication Scheme for IoT Devices," *IEEE Internet Things J.*, vol. 6, no. 1, pp. 580–589, 2019.
- [9] M. El-hajj, A. Fadlallah, M. Chmoun, and A. Serchrouchni, "A Survey of Internet of Things (IoT) Authentication Schemes †," *Sensors (Basel)*, vol. 19, no. 5, pp. 1–43, 2019.
- [10] F. Meneghello et al., "IoT: Internet of Threats? A Survey of Practical Security Vulnerabilities in Real IoT Devices," *IEEE Internet Things J.*, vol. 6, no. 5, pp. 8182–8201, 2019.
- [11] R. Román-castro and J. López, "Evolution and Trends in IoT Security," *Computer (Long. Beach. Calif.)*, vol. 51, no. 7, pp. 16–25, 2018.
- [12] A. K. Das, "Provably secure ECC-based device access control and key agreement protocol for IoT environment," *IEEE Access*, vol. 7, pp. 55382–55397, 2019.
- [13] J. Ryu et al., "Secure ECC-Based Three-Factor Mutual Authentication Protocol for Telecare Medical Information System," *IEEE Access*, vol. 10, pp. 11511–11526, 2022.
- [14] T. Kothmayr, C. Schmitt, W. Hu, M. Brünig, and G. Carle, "DTLS based security and two-way authentication for the Internet of Things q," *Ad Hoc Networks*, vol. 11, no. 8, pp. 2710–2723, 2013.
- [15] M. Nikravan, "A Multi-factor User Authentication and Key Agreement Protocol Based on Bilinear Pairing for the Internet of Things," *Wirel. Pers. Commun.*, vol. 111, no. 1, pp. 463–494, 2020.
- [16] P. Gope and T. Hwang, "Untraceable Sensor Movement in Distributed IoT Infrastructure," *IEEE Sens. J.*, vol. 15, no. 9, pp. 5340–5348, 2015.
- [17] K. L. Tsai, F. Y. Leu, I. You, S. W. Chang, S. J. Hu, and H. Park, "Low-Power AES Data Encryption Architecture for a LoRaWAN," *IEEE Access*, vol. 7, pp. 146348–146357, 2019.
- [18] G. E. Suh and S. Devadas, "Physical Unclonable Functions for Device Authentication and Secret Key Generation," *2007 44th ACM/IEEE Des. Autom. Conf. San Diego*, pp. 9–14, 2007.
- [19] W. Choi, S. Kim, Y. Kim, Y. Park, and K. Ahn, "PUF-based Encryption Processor for the RFID Systems," *2010 10th IEEE Int. Conf. Comput. Inf. Technol.*, no. Cit, pp. 2323–2328, 2010.
- [20] S. Kleber, F. Unterstein, M. Matousek, F. Kargl, F. Slomka, and M. Hiller, "Secure Execution Architecture based on PUF-driven Instruction Level Code Encryption," *LACR Cryptol. ePrint Arch. 2015*, p. 651, 2015.
- [21] Y. Guo, T. Dee, and A. Tyagi, "Barrel Shifter Physical Unclonable Function Based Encryption," *Cryptoraphy*, vol. 2, no. 3, pp. 1–20, 2018.
- [22] C. Bohm and M. Hofer, *Physical Unclonable Functions in Theory and Practice*. New York: NY, USA: Springer, 2012.
- [23] P. Tuyls and L. Batina, "RFID-Tags for Anti-counterfeiting," *Top. Cryptol. CT-RSA (LNCS 3860)*, Heidelberg, Ger. Springer, pp. 115–131, 2006.
- [24] Y. Dodis, L. Reyzin, and A. Smith, "Fuzzy Extractors : How to Generate Strong Keys from Biometrics and Other Noisy Data," *Adv. Cryptology— EUROCRYPT 2004 (Lecture Notes Comput. Sci. Heidelberg, Ger. Springer*, pp. 523–540, 2004.
- [25] D. Jeon, J. H. Baek, D. K. Kim, and B. Choi, "Toward Zero Bit-Error-Rate Physical Unclonable Function : Mismatch-Based vs . Physical-Based Approaches in Standard CMOS Technology," *2015 Euromicro Conf. Digit. Syst. Des.*, pp. 407–414, 2015.
- [26] K. Chuang et al., "A Physically Unclonable Function Using Soft Oxide Breakdown Featuring 0 % Native," *IEEE J. Solid-State Circuits*, vol. 54, no. 10, pp. 2765–2776, 2019.
- [27] X. Lu, S. Member, L. Hong, and S. Member, "CMOS Optical PUFs Using Noise-Immune Process-sensitive Photonic Crystals Incorporating Passive Variations for Robustness," *IEEE J. Solid-State Circuits*, vol. 53, no. 9, pp. 2709–2721, 2018.
- [28] W. Wang, Y. Yona, S. N. Diggavi, and P. Gupta, "Design and Analysis of Stability-Guaranteed PUFs," *IEEE Trans. Inf. FORENSICS Secur.*, vol. 13, no. 4, pp. 978–992, 2018.
- [29] S. M. R. Islam, D. Kwak, and H. Kabir, "The Internet of Things for Health Care : A Comprehensive Survey," *IEEE Access*, vol. 3, pp. 678–708, 2015.
- [30] L. Catarinucci et al., "An IoT-Aware Architecture for Smart Healthcare Systems," *IEEE Internet Things J.*, vol. 2, no. 6, pp. 515–526, 2015.
- [31] H. Habibzadeh et al., "A Survey of Healthcare Internet of Things (HIoT)," *IEEE Internet Things J.*, vol. 7, no. 1, pp. 53–71, 2020.
- [32] P. A. Laplante, M. Kassab, S. Member, N. L. Laplante, and J. M. Voas, "Building Caring Healthcare Systems in the Internet of Things," *IEEE Syst. J.*, vol. 12, no. 3, pp. 3030–3037, 2018.
- [33] M. Kaveh, "A Lightweight Mutual Authentication for Smart Grid Neighborhood Area Network Communications Based on Physically Unclonable Function," vol. 14, no. 3, pp. 4535–4544, 2020.
- [34] W. Mao and C. Boyd, "Towards formal analysis of security protocols," *[1993] Proc. Comput. Secur. Found. Work. VI*, pp. 147–158, 1993.